Synthèse de l’audit de cybersécurité

Infrastructure IoT industrielle conteneurisée

Objet : compte rendu d’un audit de sécurité réalisé dans le cadre d’un projet d’étude
Dépôt : Joshua31400/Infrastructure-IOT | **Branche :** security
Date de l’audit : 12 novembre 2026 | **Nature :** revue statique

En bref. J’ai examiné les configurations et scripts de l’infrastructure afin de repérer des faiblesses concrètes dans la gestion des certificats, l’exposition réseau et le chiffrement. L’analyse a identifié trois constats à traiter : deux de gravité élevée et un de gravité moyenne. J’ai documenté leurs impacts et des mesures correctives dans un rapport dédié.

3	2	1
constats documentés	gravité élevée	gravité moyenne

Objectif et démarche

L’objectif était d’évaluer, à partir du dépôt, si les contrôles de sécurité annoncés étaient cohérents avec les configurations effectivement fournies et de relever les risques pouvant affecter la confidentialité, l’intégrité ou l’accès aux services.

J’ai réalisé une revue statique : lecture croisée des fichiers Docker Compose par zone, des montages de certificats et des règles Mosquitto, des scripts de génération et de déploiement, des paramètres OpenVPN, LDAP, Grafana et InfluxDB, ainsi que de la documentation. J’ai vérifié en particulier les identités et permissions, les secrets, les ports publiés et les frontières réseau documentées.

Résumé des résultats

Constat	Risque principal	Gravité
Clé privée de l’autorité de certification accessible aux conteneurs IoT	Usurpation d’identité MQTT et accès étendu aux topics	**Élevée**
Services publiés sur l’hôte et SSH root avec identifiants par défaut	Accès direct aux services et prise de contrôle du conteneur d’administration	**Élevée**
HTTP pour Grafana et LDAP non chiffré exposé	Interception possible d’identifiants et de sessions	**Moyenne**

Les gravités expriment le risque potentiel des configurations observées. Elles ne signifient pas qu’une exploitation a été réalisée ou qu’un incident s’est produit.

Constats détaillés

1. Exposition de la clé privée de la CA — gravité élevée

Les services IoT montent le répertoire complet de certificats. Or, ce répertoire contient la clé privée de l'autorité de certification (CA). Un montage en lecture seule interdit la modification, mais n'empêche pas la lecture de la clé depuis le conteneur. Mosquitto fait confiance à cette CA, utilise l'identité portée par le certificat pour l'autorisation et accorde à l'identité `admin` des droits étendus sur les topics. En cas de compromission d'un capteur, cette exposition pourrait donc permettre de fabriquer une identité MQTT privilégiée.

Pourquoi c'est important : la clé de la CA doit rester sous le contrôle de l'émetteur des certificats. La distribuer à un équipement client compromet la confiance accordée à l'ensemble des certificats émis par cette CA.

Recommandations : conserver la clé de CA hors des conteneurs; monter uniquement les fichiers client nécessaires; attribuer une identité et des droits MQTT limités à chaque équipement; renouveler les certificats concernés si leur exposition est confirmée.

Zones vérifiées : `zone-a-iot/docker-compose.yml`; `certificates/generate-certs.ps1`; `zone-d-dmz/mosquitto/mosquitto.conf` et `acl.conf`.

2. Ports publiés et SSH d'administration — gravité élevée

Plusieurs ports des fichiers Compose sont publiés sans adresse d'écoute locale explicite. Docker peut alors les rendre accessibles via les interfaces réseau de l'hôte, et pas seulement depuis la machine, ce qui risque de court-circuiter les frontières réseau attendues. Parmi eux, le port SSH de l'administration est associé à une connexion root par mot de passe; les identifiants par défaut sont décrits dans la documentation. Si ce port est joignable, cette configuration expose le conteneur d'administration à un accès privilégié.

Recommandations : lier les ports de développement à `127.0.0.1` ou supprimer les publications inutiles; limiter l'exposition à une entrée contrôlée; désactiver la connexion SSH directe de root et l'authentification par mot de passe; remplacer et ne pas versionner les secrets par défaut.

Zones vérifiées : `zone-d-dmz/docker-compose.yml`; `zone-b-admin/docker-compose.yml`; documentation du dépôt.

Suite des constats

3. Chiffrement des accès web et LDAP — gravité moyenne

Grafana est configuré en HTTP et le port LDAP 389, non chiffré, est publié parallèlement à LDAPS. Un observateur présent sur un chemin réseau concerné pourrait intercepter des identifiants ou des données de session transmis sans chiffrement. La configuration LDAP contient également un secret de liaison, qui devrait être protégé et renouvelé s'il est réel ou réutilisé.

Recommandations : imposer HTTPS pour Grafana; désactiver ou restreindre LDAP en clair et vérifier les certificats TLS; sortir les secrets des fichiers versionnés; limiter l'accès réseau aux seuls clients nécessaires.

Zones vérifiées : `zone-d-dmz/docker-compose.yml`; `zone-d-dmz/grafana_config/ldap.toml`.

Priorités de remédiation

1. **Protéger la PKI :** retirer la clé privée de la CA des volumes accessibles aux clients et revoir l'émission, la portée et les ACL des certificats.
2. **Réduire l'exposition :** vérifier tous les ports publiés, leur interface d'écoute et les règles de filtrage; supprimer les publications non nécessaires.
3. **Renforcer l'administration :** désactiver SSH root et les mots de passe par défaut; utiliser des comptes nominatifs, des clés et une gestion de secrets adaptée.
4. **Chiffrer les échanges :** servir Grafana en HTTPS et imposer des connexions LDAP protégées par TLS.
5. **Valider après correction :** relire les configurations finales et tester, dans un environnement autorisé, que seuls les flux attendus sont accessibles.

Périmètre, limites et conclusion

Il s'agit d'un audit statique du contenu du dépôt; aucun test d'intrusion, déploiement, scan réseau, examen d'images en exécution ni analyse automatisée des dépendances n'a été réalisé. Les impacts décrits sont des scénarios de risque déduits des configurations, pas la preuve d'une exploitation. Les paramètres peuvent différer de l'environnement déployé : ils sont donc à vérifier avant toute conclusion opérationnelle.

Cette démarche m'a permis de relier des détails de configuration à des conséquences de sécurité concrètes : une clé d'autorité trop exposée fragilise l'identité des équipements, des ports publiés peuvent contourner la segmentation, et l'absence de chiffrement facilite l'interception. Le rapport d'audit complet fournit les éléments techniques et recommandations associés aux constats.

Rapport complet : `SECURITY-REVIEW.md` dans le dépôt. Branche examinée : `security`; synthèse préparée pour le compte rendu du projet d'étude.